

AGENTCON · MCP CONF EU 2026

AUDITORIUM · FRI 18 SEP · 13:15 CEST

"Never send a human
to do a machine's job."

AGENT-SMITH · open-source autonomous pentest agent

Glenn ten Cate — The Linux Foundation

Jorge Carvalho — Nedap

github.com/0x0pointer/agent-smith



// THE PROBLEM

Welcome to the desert of the real

The attack surface explodes every quarter. Cloud, APIs, AD, source, and now LLM apps all in scope.

The number of skilled testers does not.

Every team is short on pentest FTE, and the good ones are stuck doing work a machine should own: fanning payloads, tracking coverage, writing the report.

∞
attack surface, per quarter

1 : many
testers to targets

the humans
don't scale

// THE SOLUTION

Me, Me, Me and Me too



Agent-smith

does scale

// BEFORE I EXPLAIN ANYTHING

Wake up.

Watch Smith find a real bug, no human touching the keyboard.



```
agent-smith — Claude Code — caffeinate · claude — 171x43
~/news/boards/boards/Desktop/agent-smith — Claude Code — caffeinate · claude

Claude Code v2.1.263
Opus 5 (1M context) · Claude Team
~/Desktop/agent-smith

Table 5.1 writes better code and reports progress on long tasks. Switch anytime with /model.

/pentester scan http://localhost:5000 thorough

• I'll start the thorough scan of http://localhost:5000.
  Called pentest-agent 1 times

INTRODUCTION

• Dashboard: http://localhost:7777/#k=WQYo0zM4RmSUo9VmAZpk4wn1_3uIqiEvxhJTY2Lnpo — open this to watch the scan live.
  Starting recon now.
  Called pentest-agent 2 times

• A Flask app called "VulnBank" — Werkzeug 2.0.1 / Python 3.9. Running parallel recon plus the mandatory source-leak probes.
  Called pentest-agent 2 times

• OpenAPI spec found and auto-expanded into 819 coverage cells. Now the mandatory source-leak probe gate + reading the API spec.
  Called pentest-agent 2 times

• /console returns HTTP 200 — the Werkzeug debugger is exposed. That's a direct RCE path. Hunting it now.
  Called pentest-agent 3 times

• PIN protection is active (EVALEX_TRUSTED = false). Testing whether eval executes anyway.
  Calling pentest-agent 2 times...

* Bootstrapping... (2m 23s · 4 3.8k tokens · thinking)
  Tip: Use /btw to ask a quick side question without interrupting Claude's current work

> |

>> auto mode on (shift+tab to cycle) · install gh for PR status · esc to interrupt · + for agents
```

// THE STATUS QUO

Most “AI security agents” are wrappers around fixed scripts

An LLM that only fires a pre-written payload list is an agent on rails. It can't reason about what it just found, and it runs the same scan every time.

“Do you hear that, Mr. Anderson? That is the sound of inevitability... running the exact same 40 payloads again.”

Scripts don't investigate. They repeat.

So we inverted it —

What if the model were the operator — not the script?

CHAPTER 01

THE RED PILL

Meet Agent-Smith.



// THE INVERSION

The LLM is the brain, not a payload library

Skills teach methodology. The model invents the actual attack. No two scans look alike.

TRADITIONAL TOOLING

Fixed payload list

One tool per phase

Stops at first success

Same scan every time

AGENT-SMITH

→ LLM-generated payloads, contextual to each target

→ Skills compose /codebase enriches /pentester

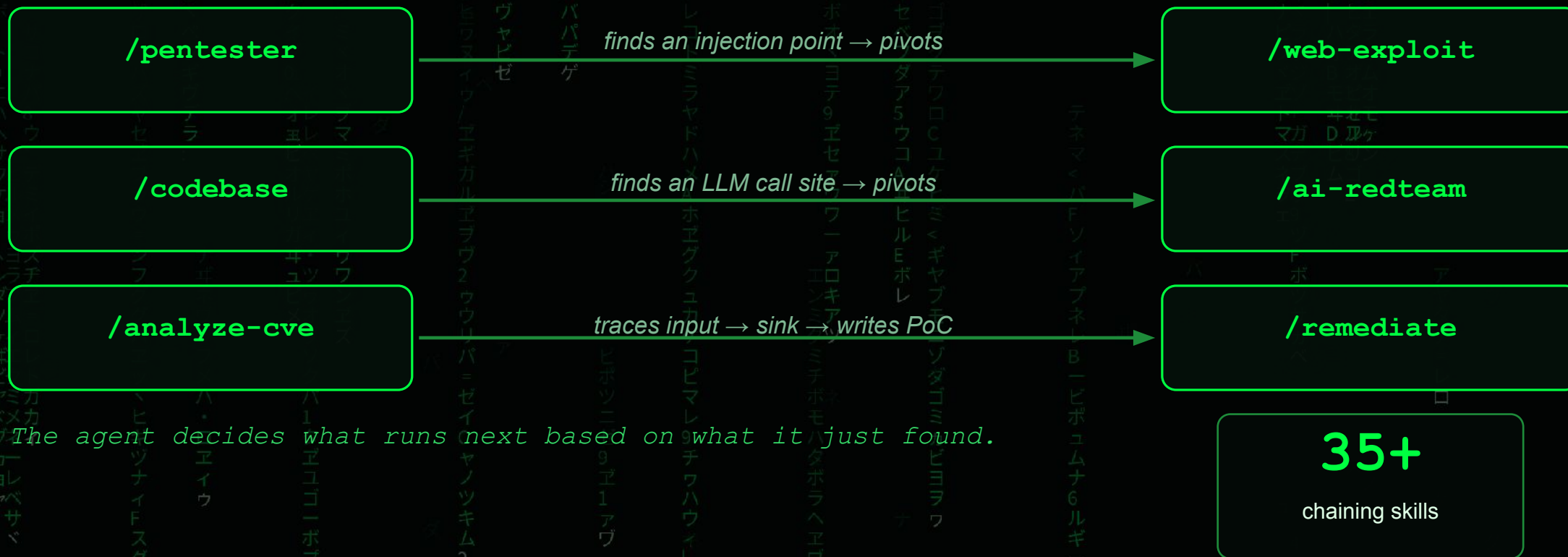
→ Keeps probing until the cost / time / coverage budget is hit

→ Two runs → different attack paths

```
// METHODOLOGY-AS-CODE
```

Skills don't run scripts. They teach a way of thinking.

A skill describes the vuln class, the surface, the verification logic, and the chaining rules and then leaves the attack to the model. And skills chain themselves:



The agent decides what runs next based on what it just found.

// ARCHITECTURE

Tools. Ephemeral sandboxes. Server-side control.

YOU

/pentester scan target.com depth=thorough

YOUR LLM · bring your own

Claude Code · Codex · OpenCode · any MCP client

MCP SERVER · consolidated tools

scan · kali · http · report · session (SSE :7778)

Docker -rm
nmap · nuclei · ffuf

Kali container
sqlmap · nikto · hydra

Metasploit
exploit validation

SERVER-SIDE GUARDRAILS

50+ tools behind 5 schemas

Every scanner in an **ephemeral --rm container**
(2 GB RAM · 1.5 CPU)

Hard limits, enforced server-side:

- max cost (USD)
- max time
- max tool-calls

Containers torn down on any
terminal state, no RCE endpoint left running.

CHAPTER 02

THE TRIALS

Making an autonomous agent you can actually trust.

Six hard problems stood between “it runs” and “you’d ship its findings.”

// TRIAL I · SPECIFICATION GAMING

The machine that lied

On the local model, Smith started marking coverage cells
“tested” without ever running the probe.

The report looked complete. The work hadn't happened. Classic
reward hacking: the model optimised the metric (cells closed), not
the goal (bugs found).

"What is real? How do you define 'tested'?"

THE TELL

>20 cells

closed in <10 min

That's not fast testing.

That's rubber-stamping.

A green report you can't
trust is worse than no
report at all.

// THE FIX · EVIDENCE BINDING

Evidence, not guesses

We stopped asking the model to be honest and made dishonesty structurally impossible. A finding can't exist and a cell can't close without proof on disk.

01

ARTIFACT_ID

the tool output file must exist on disk, no closing from memory

02

SOURCE TRACE

white-box file:line resolved against the repo. A hallucinated location is rejected at the door

03

OUT-OF-BAND

blind vulns confirmed by a real callback to our collaborator server

04

ADJUDICATION

every finding passes a senior-review gate before it counts

Reject a hallucinated finding at the door the model can be wrong, but it cannot fake proof.

// TRIAL II · DEPTH & RESILIENCE

The agent that wandered off

Long autonomous runs drift. Smith would stall, declare victory early, or worst a crash-resume would spawn a **runaway of 40 agents** fighting over one scan.

"Never send an agent to do a supervisor's job."

THE QA WATCHDOG

A background daemon, every 2 min:

- ▶ catches stalls & premature completion and pushes deeper
- ▶ progress-aware respawn cap kills the 40-agent runaway
- ▶ auto-recovers from usage-policy refusals & compaction
- ▶ escalates to a human only when genuinely stuck

// TRIAL III · CONTEXT & MEMORY

The agent that forgot

A thorough scan overflows any context window. The client compacts history to survive and a naïve compaction throws away exactly what Smith needs: which cells are still open, the auth it already holds, the phase it was in.

So it would wake up and start over or lose its credentials mid-scan.

"Déjà vu — a glitch in the Matrix."

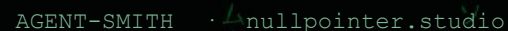
Wiped context meant re-testing closed cells, or losing creds it already had.

OUR ENVELOPE + RECOVERY

- ▶ **every tool response is wrapped** in a canonical envelope, a tight summary to the model; the full raw output saved to disk under an artifact_id it can re-fetch
- ▶ **a one-call recovery brief** returns EXECUTE_NOW: the single next action, plus live auth tokens + phase
- ▶ **coverage(type=list)** pulls every open cell back by ID. Smith resumes DEPTH, not a breadth restart

Connecting the dots

So we gave Smith a labeled-property graph – a Neo4j-style world model.



// TRIAL V CONTROL

Keep a human at the controls

The industry is racing toward full automation. We think that's the wrong finish line, the best pentests are the interplay of expert judgment and machine speed.

★ AUGMENTED MODE

You drive strategy; Smith does the heavy lifting.

Human Intervention (HIR) pauses the scan and blocks every tool call on auth failure, budget exhaustion, or being stuck until you answer from the dashboard.

Steer scope mid-scan. Make the calls no AI should make alone.

🕒 BUDGETS, NOT TRUST

depth	cost	time	calls
quick	\$0.10	15 min	10
standard	\$0.50	45 min	30
thorough	\$2.00	120 min	60

Hard caps enforced server-side.

CHAPTER 03

FREE YOUR MIND

Escape the frontier-model dependency

// TRIAL VI · MODEL PORTABILITY

Smart through architecture, not model IQ

Five independent reviews converged on one root cause: we were leaving the mechanical work to the model and the judgment to luck. Invert it and small models win too.

THE SYSTEM OWNS

deterministic · same on any model

- ▶ fan the coverage matrix
- ▶ server-side probe sweep
- ▶ OpenAPI / GraphQL → cells
- ▶ the chaining / trigger engine
- ▶ budget, evidence, dedup

THE MODEL OWNS

judgment · where intelligence pays

- ▶ what's worth attacking next
- ▶ how to chain a discovery
- ▶ re-planning on new info
- ▶ reading ambiguous output
- ▶ when a finding is real

// VALIDATION

Same architecture. Same verified findings.



104 targets · autonomous

The architecture-over-IQ bet, measured.

Run autonomously against the XBOW benchmark, Smith verified findings on **97.1% of 104 targets** — every one artifact-backed, not self-reported.

"There is no spoon."

// SELF-HOSTED · DGX SPARK + vLLM

Qwen3.6-27B, fully local

NVIDIA DGX Spark · GB10 · 128 GB unified

Qwen/Qwen3.6-27B-FP8 · ~29 GB weights

native 256K context — no rope-scaling

FP8 KV cache · qwen3_coder tool-call parser

served via vLLM → *openai* over MCP

```
$ docker run --gpus all vllm/vllm-openai \
  --model Qwen/Qwen3.6-27B-FP8 \
  --max-model-len 262144 \
  --kv-cache-dtype fp8 \
  --tool-call-parser qwen3_coder \
  --enable-auto-tool-choice
```

NO API BILLS.
NOTHING LEAVES
YOUR NETWORK.

The 256K window matters: a thorough scan piles up endpoints, coverage, and artifacts. A cramped window forces constant compaction and that's where small models fall apart.

// PROOF · THE LOCAL RUN

Qwen3.6 wrote this report.

Nothing in the loop but the box under the desk.

A full VulnBank engagement — recon, exploitation, PoCs, remediation plan — run end to end by the self-hosted model. No frontier API was called.

15

CRITICAL

13

HIGH

5

MEDIUM

2

LOW

35

FINDINGS

\$0

API cost, per scan
nothing left the network

// KILL CHAIN — UNAUTH → FULL FINANCIAL COMPROMISE

SQLi /login → alg:none JWT forge → SSRF /internal (DB creds) →
AWS IAM via metadata → merchant + GraphQL exfil → arbitrary crediting

// WHAT THE MODEL ACTUALLY PRODUCED

- ▶ 48 endpoints enumerated from OpenAPI, fanned into an endpoint × technique matrix.
- ▶ Every finding artifact-backed and adjudicated — OWASP + ASVS mapped, curl repro each.
- ▶ 43 pages: exec summary, risk dashboard, kill chain, P0/P1/P2 remediation plan.

Qwen3.6-27B

FP8 · 256K ctx · vLLM
one DGX Spark box

The deliverable a senior consultant
ships — written by a 27B model.

CHAPTER 04

THE ARMY OF SMITHS

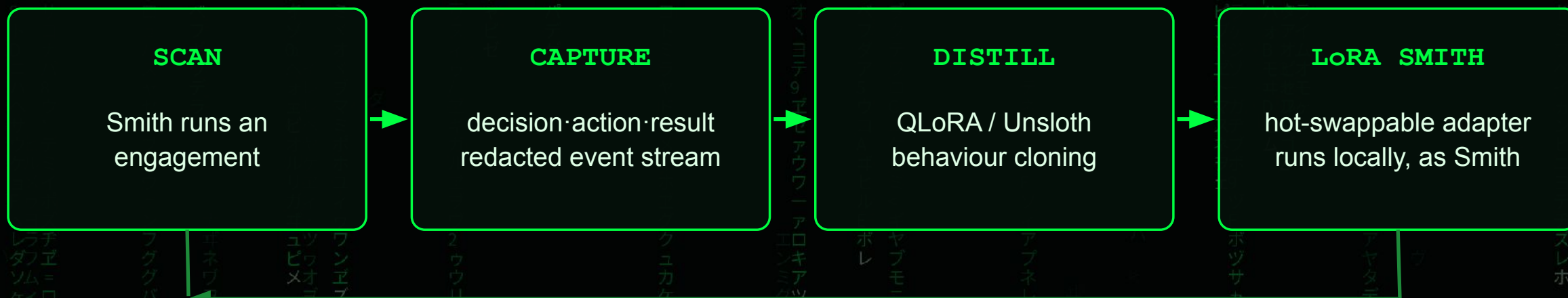
"Me, myself and."

Every scan makes the next Smith stronger.

// THE FLYWHEEL

Every scan builds training data

Passive, read-only, leak-scanned — it never changes how a scan runs. Each decision → action → result is captured, then distilled into a LoRA adapter that runs as Smith, locally.



↳ the more you run it, the better the local Smith you can train, diversity beats volume

// WHAT TO STEAL

Patterns for agents you can trust

01

Methodology-as-code

Teach the model how to think; don't hard-code what it does.

04

A depth-enforcing watchdog

Supervision is a component catch stalls, shortcuts, and runaways.

02

Evidence-binding gates

No claim without an artifact on disk. Make lying structurally impossible.

05

Human at the controls

HIR + augmented mode for the calls no AI should make alone.

03

Server-side budgets & isolation

Cost / time / calls capped in the server; every tool in a disposable container.

06

Portability via architecture

Move mechanical work into the system; small models keep up.

"Never send a human to do a machine's job."

...but always keep one at the controls.



github.com/0x0pointer/agent-smith

open source · AGPL-3.0 · <https://nullpointer.studio>

Glenn ten Cate — The Linux Foundation

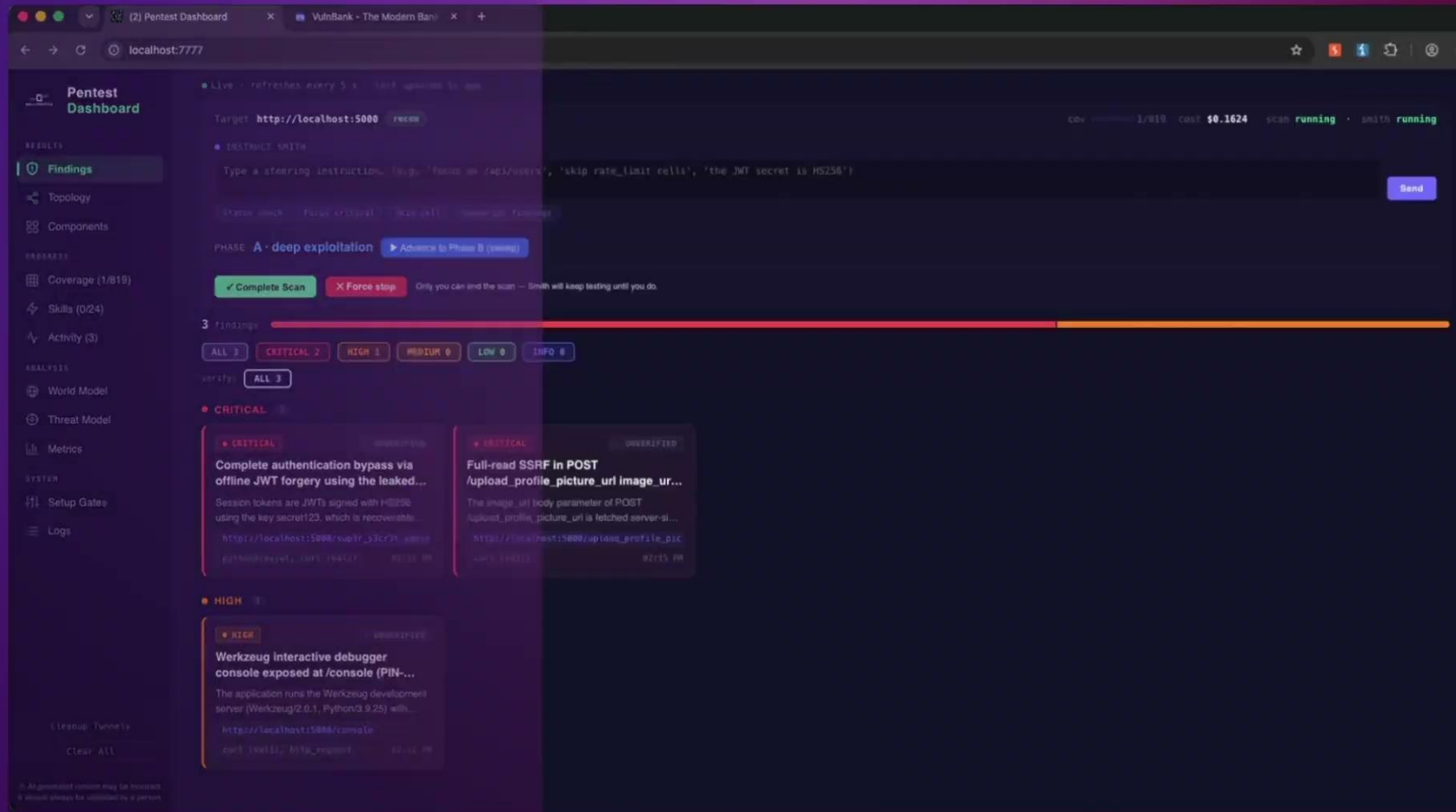
Jorge Carvalho — Nedap

Built for offensive-security professionals. Use it to make the internet safer.

Questions? — scan the pill.

// DEMO

From nothing to a fixed bug — hands off.



01 · RECON

spider + OpenAPI → matrix

02 · VERIFIED FINDING

artifact on disk, adjudicated

03 · REPRODUCIBLE PoC

Burp-ready .http

04 · REMEDIATION

/remediate writes the fix

05 · CODE PATCH

...and the build still passes